

Incident Response Plan

Owner: Mark Stolte, Founder — markstolte02@gmail.com

Last reviewed: 2026-07-05

Stage: Pre-launch / active development

Incident contact: markstolte02@gmail.com

Purpose

Defines what counts as a security incident for Penny Pilot, and the concrete steps taken in response, so that a response doesn't have to be improvised from scratch under pressure.

What counts as an incident

- Unauthorized access to, or exfiltration of, any Restricted or Confidential-tier data as defined in [Data Classification & Handling](#) — most importantly, Plaid access tokens, transaction data, or Supabase session tokens.
- Compromise of any operator/admin account listed in the [Access Control Policy](#) table (GitHub, Supabase, Plaid, Apple Developer, Google Cloud/Play Console, Expo/EAS).
- Suspected compromise of the Plaid token-encryption key or the Supabase service-role key.
- A vulnerability that is confirmed to have been actively exploited (as opposed to merely discovered — see [Vulnerability Management](#) for the non-exploited case).
- Loss of availability of the app or backend that is caused by malicious activity rather than ordinary operational failure (the latter is covered by [Business Continuity & Disaster Recovery](#)).

Response steps

1. Identify and contain

- Confirm the scope: which system, which data tier, which users (if any) are affected.
- If a **Plaid access token or the token-encryption key** is suspected compromised: rotate `PLAID_TOKEN_ENCRYPTION_KEY` immediately via `supabase secrets set PLAID_TOKEN_ENCRYPTION_KEY=<new value>`. Note that rotating the key without re-encrypting existing rows makes existing `access_token_ciphertext` values undecryptable — the practical response is to also call Plaid's `/item/remove` for affected items and prompt affected users to re-link, rather than attempt in-place re-encryption under incident pressure.

- If the **Supabase service-role key** is suspected compromised: rotate it from the Supabase dashboard immediately; this key is only ever used server-side in Edge Functions, so rotating it and redeploying functions with the new value fully contains this vector.
- If an **operator/admin account** (GitHub, Supabase, Plaid, Apple, Google, Expo) is suspected compromised: revoke its active sessions, rotate its password, and review its audit log (where the vendor provides one) for unauthorized changes.
- If a **Supabase session token** is suspected compromised for a specific user: that session can be revoked from the Supabase Auth dashboard; the user should be prompted to re-authenticate.

2. Eradicate

Remove the root cause — patch the vulnerability, revoke the compromised credential permanently (not just rotate), or close the misconfiguration (e.g., a Row Level Security policy gap).

3. Recover

Restore normal operation: redeploy Edge Functions with rotated secrets, confirm RLS policies are intact, confirm Plaid items affected users need to re-link are surfaced to them in-app rather than silently failing.

4. Notify

- **Users:** if the incident exposed Restricted or Confidential-tier data belonging to identifiable users, they are notified directly (email, using the address Supabase Auth already has for them) describing what happened, what data was involved, and what action they should take (e.g., re-link their bank).
- **Vendors:** Plaid and Supabase are notified if the incident involves their systems or credentials they issued, since they may have their own obligations or mitigations.
- **Legal/regulatory:** once Penny Pilot has real users, applicable breach-notification law (state-level in the U.S., and any jurisdiction-specific requirement for users elsewhere) is assessed per-incident. No specific regulatory notification process is pre-built yet, since there are no production users as of this review — this is flagged as a pre-launch action item, not an oversight to be discovered later.

5. Post-incident review

Every incident gets a short written record: what happened, root cause, what was done, what will change (a code fix, a new alert, a policy update) to prevent recurrence. This document and the relevant subordinate policy are updated if the incident revealed a gap.

Known current limitation

As a solo-operator team, there is no on-call rotation and no guarantee of immediate response outside the founder's availability. This is disclosed rather than hidden; it is the first process gap to close as the team grows or as the app takes on production financial data at scale.